

Security+ 3.4 · Backups

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.4 — Backups (12:16)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Frequência (por hora/dia/semana) + retention (quantos backups mantém); incremental (desde o último backup); differential (desde o último FULL). Snapshot: estado instantâneo. Replicação: tempo real. Regra 3-2-1: 3 cópias, 2 mídias, 1 offsite.

Highlights que a prova cobra

- Incremental: desde o último backup (rápido, muitos arquivos small)
- Differential: desde o FULL (menos rápido, mais robusto)
- 3-2-1: 3 cópias, 2 mídias, 1 offsite; backup offline sobrevive ransomware

Dicas de prova & Cenários Típicos

- 'copies data since the last full backup'=differential
- '3 copies, 2 media types, 1 offsite'=3-2-1 rule

Cenário clássico de exame: 'backup de segunda só copia o que mudou desde o FULL de domingo'=differential.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.4 — Backups)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um bucket S3 configurado com bloqueio de acesso público está protegido contra:

- A) Acesso não autorizado via internet
- B) Exclusão acidental
- C) Criptografia fraca
- D) Vazamento de metadados

2. Qual recurso do S3 garante durabilidade de 99.99999999% (11 noves)?

- A) Criptografia at-rest
- B) Versionamento e replicação cross-AZ
- C) Lifecycle policies
- D) Transfer Acceleration

3. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Incremental: desde o último backup (rápido, muitos arquivos small)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Incremental: desde o último backup (rápido, muitos arquivos small)...

4. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Differential: desde o FULL (menos rápido, mais robusto)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Differential: desde o FULL (menos rápido, mais robusto)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: '3-2-1: 3 cópias, 2 mídias, 1 offsite; backup offline sobrevive ransomware'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 3-2-1: 3 cópias, 2 mídias, 1 offsite; backup offline sobrevive ransomware...

6. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: "copies data since the last full backup'=differential'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'copies data since the last full backup'=differential...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: "3 copies, 2 media types, 1 offsite'=3-2-1 rule'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: '3 copies, 2 media types, 1 offsite'=3-2-1 rule...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: "backup de segunda só copia o que mudou desde o FULL de domingo'=differential.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'backup de segunda só copia o que mudou desde o FULL de domingo'=differenti...

9. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Incremental: desde o último backup (rápido, muitos arquivos small)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Incremental: desde o último backup (rápido, muitos arquivos small)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Backups): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Differential: desde o FULL (menos rápido, mais robusto)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Differential: desde o FULL (menos rápido, mais robusto)...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Acesso não autorizado via internet.

✓ **Por que está certa:** Um bucket S3 configurado com bloqueio de acesso público (Block Public Access) impede que políticas de bucket ou de objeto concedam acesso público não autenticado via internet. Isso significa que qualquer tentativa de acesso anônimo ou não autorizado pela internet é negada, a menos que o solicitante tenha credenciais válidas e permissões explícitas. Esse controle é fundamental para evitar vazamentos de dados, que são uma das principais causas de incidentes em nuvem. No CompTIA Security+, a configuração de bloqueio de acesso público é um exemplo de controle de segurança em nuvem para proteger a confidencialidade dos dados armazenados em serviços de object storage.

✗ **Por que as outras estão erradas:**

- *Exclusão acidental:* A exclusão acidental é mitigada por controles como versionamento, MFA Delete e políticas de retenção (Object Lock). O bloqueio de acesso público não impede exclusão acidental, pois ele atua apenas no controle de acesso, não na integridade ou disponibilidade dos objetos. Portanto, a alternativa está errada porque confunde um controle de confidencialidade com um controle de disponibilidade/integridade.
- *Criptografia fraca:* A criptografia fraca refere-se ao uso de algoritmos ou chaves inadequadas para proteger dados. O bloqueio de acesso público não tem relação com a força da criptografia; ele apenas restringe quem pode acessar o bucket. Mesmo com criptografia forte, um bucket público pode expor dados se as permissões forem mal configuradas. A alternativa está incorreta porque aborda um aspecto diferente da segurança (força criptográfica) e não o controle de acesso.
- *Vazamento de metadados:* Metadados de objetos S3 incluem informações como nome, tamanho, data de modificação e tags. O bloqueio de acesso público impede o acesso não autorizado ao conteúdo e também aos metadados, mas o foco principal é o conteúdo. Além disso, vazamento de metadados pode ocorrer por outras vias, como logs ou APIs mal configuradas. A alternativa está errada porque o bloqueio de acesso público não é especificamente projetado para proteger metadados, mas sim para negar acesso público ao bucket como um todo.

2) B — Versionamento e replicação cross-AZ.

✓ **Por que está certa:** A alternativa correta é 'Versionamento e replicação cross-AZ'. O Amazon S3 oferece durabilidade de 99,999999999% (11 noves) porque armazena cada objeto de forma redundante em múltiplas instalações dentro de uma região, distribuídas em pelo menos três Zonas de Disponibilidade (AZs). O versionamento protege contra exclusões acidentais e sobrescritas, mantendo versões anteriores dos objetos, enquanto a replicação cross-AZ (e também a replicação cross-region, opcional) garante que os dados existam em locais fisicamente separados. Essa combinação de redundância geográfica e histórico de versões é o que sustenta a durabilidade de 11 noves. A CompTIA aborda durabilidade como a probabilidade de os dados não serem perdidos, e no S3 isso é alcançado pela replicação automática entre AZs e pelo versionamento.

✗ **Por que as outras estão erradas:**

- *Criptografia at-rest:* Criptografia at-rest protege os dados contra acesso não autorizado quando armazenados, usando chaves gerenciadas pelo S3 (SSE-S3), KMS (SSE-KMS) ou pelo cliente (SSE-C). Ela é uma medida de confidencialidade, não de durabilidade. Não impede perda de dados por falha de hardware, exclusão acidental ou corrupção; portanto, não é o recurso que garante os 11 noves de durabilidade.
- *Lifecycle policies:* Lifecycle policies são regras que automatizam a transição de objetos entre classes de armazenamento (ex.: Standard para Glacier) ou a expiração/exclusão após um período. Elas ajudam a otimizar custos e gerenciar o ciclo de vida dos dados, mas não aumentam a

durabilidade intrínseca do S3. Na verdade, políticas mal configuradas podem levar à exclusão de dados, reduzindo a disponibilidade. Não é o mecanismo que assegura os 11 noves.

- *Transfer Acceleration*: Transfer Acceleration é um recurso que usa os edge locations da CloudFront para acelerar uploads e downloads de longa distância, melhorando a performance de transferência. Não tem relação com durabilidade ou redundância de armazenamento; é uma otimização de rede. Portanto, não contribui para a garantia de 99,999999999% de durabilidade.

3) D — Implementar a solução correspondente: Incremental: desde o último backup (rápido, muitos arquivos small)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): Incremental: desde o último backup (rápido, muitos arquivos small).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Differential: desde o FULL (menos rápido, mais robusto)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): Differential: desde o FULL (menos rápido, mais robusto).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 3-2-1: 3 cópias, 2 mídias, 1 offsite; backup offline sobrevive ransomware....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): 3-2-1: 3 cópias, 2 mídias, 1 offsite; backup offline sobrevive ransomware.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'copies data since the last full backup'=differential....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): 'copies data since the last full backup'=differential.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: '3 copies, 2 media types, 1 offsite'=3-2-1 rule....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): '3 copies, 2 media types, 1 offsite'=3-2-1 rule.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: 'backup de segunda só copia o que mudou desde o FULL de domingo'=differenti....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): 'backup de segunda só copia o que mudou desde o FULL de domingo'=differenti..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: Incremental: desde o último backup (rápido, muitos arquivos small)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): Incremental: desde o último backup (rápido, muitos arquivos small).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Differential: desde o FULL (menos rápido, mais robusto)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Backups): Differential: desde o FULL (menos rápido, mais robusto).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.